

WORKING PAPER

AUDIT INTERNAL SMKI

ISO/IEC 27001:2022 - Lembar Kerja Lapangan Auditor

PT JELAJAH DUNIA

Lingkup Sertifikasi: Sistem Manajemen Keamanan Informasi dalam Operasional E-Commerce Pemesanan Tiket Online

Nomor Working Paper	WP-01 s.d. WP-03 / ISMS / I / 2026
Jenis Audit	Audit Internal - Pihak Pertama
Periode Audit	6 - 24 Januari 2026
Tanggal Penyusunan	24 Januari 2026
Ketua Tim Audit	Syahril Arfian Almazril
Standar Acuan	ISO/IEC 27001:2022; ISO 19011:2018; Kebijakan Internal PT Jelajah Dunia
Klasifikasi Dokumen	RAHASIA - Hanya untuk pihak yang berkepentingan

*Dokumen ini merupakan working paper (lembar kerja) auditor selama pelaksanaan fieldwork.
Bersifat working draft dan menjadi lampiran teknis dari Laporan Audit Formal LAI/ISMS/001/I/2026.*

Daftar Isi

WP 1. Human Capital - Background Screening

- 1.I Working Paper
- 1.II Daftar Temuan Sementara (Corrective Action Plan / CAP)
- 1.III Catatan Auditee

WP 2. IT GRC - Risk Management & Access Control

- 2.I Working Paper
- 2.II Daftar Temuan Sementara (Corrective Action Plan / CAP)
- 2.III Catatan Auditee

WP 3. Engineering - Change Management & Network Security

- 3.I Working Paper
- 3.II Daftar Temuan Sementara (Corrective Action Plan / CAP)
- 3.III Catatan Auditee

WP 1: Human Capital

Background Screening - Pemeriksaan Latar Belakang Kandidat

I. WORKING PAPER | Auditor: Syahril Arfian Almazril

No.	Clause / Annex	Detail Clause/Annex	Control Objective	List of Questions	Interview Notes / Audit Findings	Status (C/NC/OFI)	Opportunity for Improvement (OFI)	PIC
1	Annex A.6.1	Screening	Background verification checks on all candidates to become personnel shall be carried out prior to joining the organization and on an ongoing basis taking into consideration applicable laws, regulations and ethics and be proportional to the business requirements, the classification of the information to be accessed and the perceived risks.	Bagaimana proses pengumpulan dan verifikasi SKCK untuk seluruh karyawan baru sesuai PNP/HC/012/2023 v1.2? Berapa lama SLA pengumpulan SKCK pasca-onboarding? Apakah terdapat mekanisme blocking item dalam sistem onboarding apabila SKCK belum diserahkan?	Berdasarkan pemeriksaan data karyawan baru 1 tahun terakhir, ditemukan 5 dari 10 karyawan baru (50%) tidak menyerahkan SKCK: Andi Pratama Wijaya (HR Staff, 17 Okt 2025), Dewi Maharani Sasmita (IT GRC, 16 Okt 2025), Eko Budi Prasetyo (iOS Engineer, 1 Nov 2025), Maya Sari Purnamasari (Finance Staff, 18 Des 2025), Rendy Kurniawan Putra (Onboarding Specialist, 1 Jan 2026). Wawancara 14 Januari 2026 dengan Lorent Aprilia (HC Staff) dan Rina Clarissa (Head of HC): tindak lanjut pengumpulan SKCK terlupakan; PIC onboarding HC mengundurkan diri September 2025 menyebabkan diskontinuitas proses. 5 karyawan lain (Ayu Lestari, Bagas Nugroho, Citra Melati, Fitri Nur Aisyah, Hadi Susanto) telah memenuhi.	NC (Major)	Implementasi onboarding checklist digital pada HRIS yang menempatkan SKCK sebagai blocking item sebelum status karyawan berubah menjadi active. Tetapkan backup PIC untuk setiap proses kritikal HC guna mencegah diskontinuitas akibat turnover.	Azril
2	Annex A.6.2	Terms and Conditions of Employment	The employment contractual agreements shall state the personnel's and the organization's responsibilities for information security.	Apakah kontrak kerja seluruh karyawan baru (termasuk 10 sampel) mencantumkan tanggung jawab keamanan informasi secara eksplisit? Apakah ada klausul kerahasiaan, perlakuan data, dan kepatuhan terhadap kebijakan SMKI?	Pemeriksaan kontrak kerja dan SOP HR tidak menemukan pelanggaran spesifik atas A.6.2 berdasarkan studi kasus yang tersedia. Tidak terdapat indikasi bahwa kontrak kerja gagal mencantumkan tanggung jawab keamanan informasi. Area ini tidak diperdalam karena cakupan audit individual terbatas; verifikasi penuh disarankan pada audit komprehensif berikutnya.	Conform	Sebagai praktik baik, lakukan tinjauan periodik (tahunan) atas template kontrak kerja untuk memastikan klausul keamanan informasi selaras dengan perubahan kebijakan SMKI dan regulasi UU PDP No. 27/2022.	Azril

II. DAFTAR TEMUAN SEMENTARA - Corrective Action Plan (CAP)

Auditor: Syahril Arfian Almazril

No.	Ref Clause / Annex	Finding Detail (Method: CPLOR + Risiko)	Finding Rating	Root Cause Analysis (RCA)	Corrective Action Plan (CAP)	Due Date	Status
1	Annex A.6.1 PNP/HC/012/2023 v1.2	C: PT Jelajah Dunia telah menetapkan Kebijakan Pemeriksaan Latar Belakang Kandidat (PNP/HC/012/2023 v1.2) yang mewajibkan setiap kandidat menyerahkan SKCK valid (maksimal 3 bulan sebelum pengajuan) dan menugaskan Tim HC sebagai pihak verifikasi. 5 dari 10 karyawan baru telah memenuhi persyaratan. P: 5 dari 10 karyawan baru (50%) yang bergabung dalam periode 1 tahun terakhir tidak menyerahkan SKCK. Tindak lanjut pengumpulan SKCK belum dilaksanakan oleh Tim HC. L: Departemen Human Capital, Kantor Pusat PT Jelajah Dunia, Gedung 456, Pasar Minggu, Jakarta Selatan. O: Tinjauan data master karyawan baru menunjukkan 5 karyawan tanpa SKCK (Andi, Dewi, Eko, Maya, Rendi). Wawancara Lorent Aprilia dan Rina Clarissa pada 14 Januari 2026 mengakui: (1) tindak lanjut terlupakan; (2) PIC onboarding mengundurkan diri September 2025. R: ISO/IEC 27001:2022 Annex A.6.1 Screening; Kebijakan Internal PNP/HC/012/2023 v1.2 butir 1 dan butir 4. Risiko: Potensi rekrutmen kandidat dengan rekam jejak kriminal - insider threat khususnya pada posisi IT GRC, iOS Engineer, Finance Staff. Potensi temuan Major NC pada External Surveillance Audit Juni 2026 yang berdampak pada kelangsungan sertifikasi.	Major	Tidak adanya mekanisme blocking item / gating otomatis pada proses onboarding yang memastikan SKCK menjadi prasyarat sebelum status karyawan menjadi active. Turnover PIC onboarding pada September 2025 tidak memiliki proses handover yang memadai dan tidak ada backup PIC, menyebabkan diskontinuitas pelaksanaan kontrol.	- Tim HC segera melakukan recall dan mengumpulkan SKCK dari 5 karyawan terdampak (SLA penyerahan maksimal 14 hari kerja sejak follow-up resmi). - Implementasi onboarding checklist digital (HRIS/workflow system) yang menempatkan SKCK sebagai blocking item sebelum status karyawan berubah menjadi active. - Tetapkan backup PIC untuk setiap proses kritikal HC guna mencegah diskontinuitas akibat turnover. - Lakukan tinjauan ulang Kebijakan PNP/HC/012/2023 untuk menambahkan klausul SLA tindak lanjut dan mekanisme eskalasi.	30 hari (jangka pendek); 60 hari (sistemik) sejak tanggal closing meeting	Open

III. CATATAN AUDITEE - Response & Evidence

Auditee: Rina Clarissa (Head of Human Capital); Lorent Aprilia (Human Capital Staff)

Due Date	Finish Date	Response, Commitment, & Evidence	Evidence	Remark

WP 2: IT GRC

Risk Management & Access Control - Manajemen Risiko & Pengendalian Akses

I. WORKING PAPER | Auditor: Syahril Arfian Almazril

No.	Clause / Annex	Detail Clause/Annex	Control Objective	List of Questions	Interview Notes / Audit Findings	Status (C/NC/OFI)	Opportunity for Improvement (OFI)	PIC
1	Clause 6.1.2	Information Security Risk Assessment	The organization shall define and apply an information security risk assessment process that establishes risk criteria, ensures consistent results, identifies risks and risk owners, analyses and evaluates the information security risks.	Bagaimana metodologi penilaian risiko (RA) yang diterapkan PT Jelajah Dunia? Apakah terdapat kriteria penerimaan risiko (risk acceptance criteria) dan kriteria pelaksanaan RA yang terdokumentasi? Siapa risk owner yang ditugaskan?	Berdasarkan tinjauan dokumen, PT Jelajah Dunia telah melaksanakan Risk Assessment terakhir pada April 2025 dengan dokumentasi yang tersedia, kriteria penilaian risiko yang ditetapkan, dan pemilik risiko teridentifikasi. Proses RA berjalan sesuai pendekatan manajemen risiko yang ditetapkan. Tidak ditemukan ketidaksesuaian terhadap persyaratan proses RA pada periode April 2025.	Conform	Pertimbangkan dokumentasi metodologi RA yang lebih eksplisit termasuk risk acceptance criteria dan threshold kuantitatif untuk meningkatkan konsistensi penilaian antar periode dan tim.	Azril
2	Clause 8.2	Information Security Risk Assessment (Operational)	The organization shall perform information security risk assessments at planned intervals or when significant changes are proposed or occur, taking account of the criteria established in 6.1.2 a). The organization shall retain documented information of the results.	Apakah RA dilakukan setiap interval terjadwal? Apakah RA dipicu ulang ketika terjadi perubahan signifikan (misalnya relokasi kantor)? Bagaimana mekanisme trigger event-driven RA dalam metodologi?	RA terakhir dilaksanakan April 2025. Pada Juni-Agustus 2025 terjadi perubahan signifikan: relokasi kantor utama dari Gedung 123 Bojongsoang Bandung ke Gedung 456 Pasar Minggu Jakarta Selatan (kronologi: Juni operasional pindah; Juli infrastruktur IT pindah; Agustus operasional Bandung dihentikan). Per 6 Januari 2026, selisih waktu lebih dari 6 bulan tanpa pemutakhiran RA. Seluruh risiko dalam dokumen RA masih merujuk profil ancaman kantor lama di Bandung.	NC (Major)	Tetapkan pemicu RA berbasis event-driven (bukan hanya kalender) dengan daftar trigger event eksplisit: relokasi, akuisisi, perubahan teknologi material, insiden major, perubahan vendor utama.	Azril
3	Annex A.5.15	Access Control	Rules to control physical and logical access to information and other associated assets shall be established and implemented based on business and information security requirements.	Bagaimana implementasi aturan kontrol akses fisik dan logikal pada sistem produksi (GCP), critical apps, dan repository (GitHub)? Apakah access review dilakukan sesuai kebijakan PNP/IT/002/2023 v1.1 setiap kuartal? Tunjukkan	Q1 2025: access review lengkap (GCP, Critical Apps, GitHub) - Conform. Q2 2025: access review lengkap - Conform. Q3 2025: access review TIDAK LENGKAP - hanya GCP, tanpa Critical Apps dan GitHub. Q4 2025: BELUM DILAKSANAKAN, dijadwalkan Januari 2026. Total 2 kuartal berturut-turut menyimpang. Wawancara Tim IT GRC: sejak Q3 2025 hanya 1	NC (Major)	Implementasi Identity Governance & Administration (IGA) tool dengan automated access certification campaign dan continuous monitoring. Sebagai quick win, otomasi access review report generation dari sistem IAM.	Azril

No.	Clause / Annex	Detail Clause/Annex	Control Objective	List of Questions	Interview Notes / Audit Findings	Status (C/NC/OFI)	Opportunity for Improvement (OFI)	PIC
				bukti pelaksanaan access review Q1-Q4 2025.	anggota tim akibat keterbatasan SDM. Tidak ada bukti eskalasi resmi sebagaimana diwajibkan butir 3 kebijakan.			
4	Annex A.5.18	Access Right	Access rights to information and other associated assets shall be provisioned, reviewed, modified and removed in accordance with the organization's topic-specific policy on and rules for access control.	Apakah hak akses pengguna direviu, dimodifikasi, dan dicabut secara konsisten? Bagaimana siklus provisioning-modification-removal hak akses dijalankan? Apakah pencabutan akses tepat waktu untuk karyawan resign atau berubah peran?	Mekanisme provisioning, modifikasi, dan removal hak akses telah diatur dalam PNP/IT/002/2023 v1.1. Namun, kewajiban review berkala hak akses pengguna - subset dari proses access review kuartalan - TIDAK TERLAKSANA PENUH pada Q3 2025 (lingkup tidak lengkap) dan Q4 2025 (belum dilaksanakan). Akibatnya, hak akses pengguna terhadap critical apps dan GitHub tidak melalui siklus review-modify-remove yang konsisten selama 6 bulan terakhir.	NC (Major)	Tetapkan KPI dan escalation path yang terdokumentasi untuk memastikan setiap siklus review hak akses (termasuk perubahan peran dan pencabutan) dieskalasi secara formal jika terjadi keterlambatan.	Azril

II. DAFTAR TEMUAN SEMENTARA - Corrective Action Plan (CAP)

Auditor: Syahril Arfian Almazril

No.	Ref Clause / Annex	Finding Detail (Method: CPLOR + Risiko)	Finding Rating	Root Cause Analysis (RCA)	Corrective Action Plan (CAP)	Due Date	Status
1	Clause 8.2 Clause 6.1.2	C: PT Jelajah Dunia telah melaksanakan Risk Assessment terakhir pada April 2025 dengan dokumentasi tersedia dan risk owner teridentifikasi. P: Risk Assessment belum diperbarui untuk mencerminkan perubahan signifikan (significant change) berupa relokasi kantor utama. Selisih waktu sudah lebih dari 6 bulan. L: Departemen IT Governance, Risk, and Compliance (GRC) - dokumen Risk Register dan Risk Assessment. O: Tinjauan dokumen RA April 2025 - seluruh risiko mengacu pada lokasi Gedung 123 Bojongsoang Bandung. Kronologi relokasi (Juni-Agustus 2025) terdokumentasi. Per 6 Januari 2026, tidak ditemukan dokumen RA pemutakhiran maupun delta risk assessment. R: ISO/IEC 27001:2022 Clause 8.2 dan Clause 6.1.2. Risiko: Ancaman baru lokasi Jakarta (kepadatan urban, kejahatan siber, banjir, regulasi, dependensi vendor baru) tidak tercakup. Kontrol kompensasi mungkin tidak	Major	Metodologi RA hanya berbasis kalender (annual), tidak memiliki trigger event-driven untuk significant change. Tidak adanya mekanisme review post-change yang otomatis terhadap dokumen RA setelah perubahan signifikan terjadi.	1. Tim IT GRC segera melaksanakan risk assessment refresh khusus dampak relokasi (lokasi fisik baru, vendor lokal, kontrol akses gedung, business continuity, dependensi infrastruktur), disahkan oleh risk owner. 2. Selaraskan hasil RA baru dengan SoA, Risk Treatment Plan, dan BCP; sahkan via MRM. 3. Update metodologi RA untuk memasukkan trigger event-driven dengan daftar trigger eksplisit.	30 hari (RA refresh); 60 hari (sinkronisasi SoA/RTP/BCP) sejak closing meeting	Open

No.	Ref Clause / Annex	Finding Detail (Method: CPLOR + Risiko)	Finding Rating	Root Cause Analysis (RCA)	Corrective Action Plan (CAP)	Due Date	Status
		memadai. Pelanggaran klausul mandatori 8.2 umumnya menjadi showstopper dalam surveillance audit.					
2	Annex A.5.15 Annex A.5.18 PNP/IT/002/2023 v1.1	C: PT Jelajah Dunia memiliki Kebijakan Manajemen Akses (PNP/IT/002/2023 v1.1) yang mewajibkan access review setiap kuartal. Q1 dan Q2 2025 dilaksanakan lengkap. P: Access review Q3 2025 tidak lengkap (hanya GCP, tanpa Critical Apps dan GitHub). Access review Q4 2025 belum dilaksanakan. Total 2 kuartal berturut-turut menyimpang dari kebijakan. L: Departemen IT GRC. Sistem terdampak: GCP, Critical Business Applications, GitHub Repository. O: Tabel pelaksanaan access review Q1-Q4 2025 menunjukkan deviasi pada Q3 dan Q4. Wawancara Tim IT GRC: sejak Q3 2025 hanya 1 anggota tim. Tidak ada bukti eskalasi resmi. R: ISO/IEC 27001:2022 Annex A.5.15 dan A.5.18; Kebijakan Internal PNP/IT/002/2023 butir 1 dan butir 3. Risiko: Akses stale dan orphan account; privilege creep; insider threat terhadap GitHub (memuat source code aplikasi produksi); kegagalan mekanisme eskalasi tata kelola.	Major	Keterbatasan kapasitas Tim IT GRC (hanya 1 anggota sejak Q3 2025) tanpa rencana mitigasi yang dieskalasi secara formal. Tidak adanya otomasi access review yang dapat mengurangi manual effort.	1. Selesaikan access review Q4 2025 untuk seluruh sistem (prioritas: GitHub). 2. Lakukan retroactive review untuk gap Q3 2025 pada Critical Apps dan GitHub. 3. Penambahan kapasitas Tim IT GRC (rekrutmen atau cross-functional assignment). 4. Otomasi access review report generation dari sistem IAM (quick win). 5. Implementasi IGA tool jangka panjang dengan automated certification campaign.	21 hari (Q4 + retro Q3); 60 hari (kapasitas tim) sejak closing meeting	Open

III. CATATAN AUDITEE - Response & Evidence

Auditee: Tim IT Governance, Risk, and Compliance (GRC) PT Jelajah Dunia

Due Date	Finish Date	Response, Commitment, & Evidence	Evidence	Remark

WP 3: Engineering

Change Management & Network Security - Manajemen Perubahan & Keamanan Jaringan

I. WORKING PAPER | Auditor: Syahril Arfian Almazril

No.	Clause / Annex	Detail Clause/Annex	Control Objective	List of Questions	Interview Notes / Audit Findings	Status (C/NC/OFI)	Opportunity for Improvement (OFI)	PIC
1	Annex A.8.32	Change Management	Changes to information processing facilities and information systems shall be subject to change management procedures.	Bagaimana proses formal Change Request (CR) dijalankan? Apakah seluruh perubahan production memiliki approval lengkap sebelum implementasi? Tunjukkan sampel 5 CR terakhir dan verifikasi konsistensi proses approval dengan kebijakan PNP/IT/004/2023 v1.1.	Dari 5 sampel CR yang ditinjau, 4 CR telah menjalankan proses approval dengan benar: CR 1011 (Deploy app ABCD v2.1), CR 1000 (perubahan konfigurasi password Google Workspace), CR 997 (security patch database 'db-abcd-01'), CR 956 (security patch temuan VAPT aplikasi ABCD). Namun CR 1010 (penambahan firewall rule untuk aset 'fw-xyz-01') TELAH DIIMPLEMENTASIKAN DI PRODUCTION untuk memblokir traffic, NAMUN belum mendapatkan persetujuan lengkap dari Infrastructure Lead dan Business Operations Lead. Pelanggaran langsung terhadap butir 2 (Persetujuan Wajib) kebijakan.	NC (Major)	Implementasi technical enforcement pada change management system berupa workflow gating - perubahan tidak dapat dieksekusi di production jika status approval belum lengkap. Integrasi dengan IaC pipeline dan CI/CD dengan policy-as-code untuk firewall changes.	Azril
2	Annex A.8.20	Networks Security	Networks and network devices shall be secured, managed and controlled to protect information in systems and applications.	Bagaimana pengamanan dan pengelolaan perubahan pada perangkat jaringan production (terutama firewall)? Apakah seluruh firewall rule production melalui mekanisme kontrol perubahan dan peer-review? Tunjukkan bukti tata kelola perubahan pada firewall 'fw-xyz-01'.	Konfigurasi production firewall 'fw-xyz-01' menunjukkan adanya firewall rule aktif yang memblokir traffic masuk dan keluar sesuai cakupan CR 1010, NAMUN perubahan tersebut belum melalui kontrol perubahan jaringan yang lengkap (lihat A.8.32). Kondisi ini mengindikasikan bahwa pengamanan jaringan production tidak sepenuhnya melalui mekanisme kontrol manajemen yang dipersyaratkan A.8.20 - terdapat gap antara implementasi perubahan jaringan dengan governance-nya.	NC (Major)	Pertimbangkan implementasi network change tracking yang terintegrasi dengan Configuration Management Database (CMDB) untuk memastikan setiap perubahan firewall rule memiliki jejak persetujuan, peer-review, dan rollback plan.	Azril

II. DAFTAR TEMUAN SEMENTARA - Corrective Action Plan (CAP)

Auditor: Syahril Arfian Almazril

No.	Ref Clause / Annex	Finding Detail (Method: CPLOR + Risiko)	Finding Rating	Root Cause Analysis (RCA)	Corrective Action Plan (CAP)	Due Date	Status
1	Annex A.8.32 Annex A.8.20 PNP/IT/004/2023 v1.1	C: PT Jelajah Dunia telah menetapkan Kebijakan Manajemen Perubahan (PNP/IT/004/2023 v1.1). Dari 5 sampel CR, 4 CR telah melalui proses approval dengan benar (CR 1011, 1000, 997, 956). P: CR 1010 (penambahan firewall rule untuk aset 'fw-xyz-01') telah diimplementasikan di production tanpa persetujuan lengkap dari Infrastructure Lead dan Business Operations Lead. L: Tim Engineering. Aset terdampak: perangkat firewall 'fw-xyz-01' pada lingkungan production. O: Pemeriksaan konfigurasi production firewall menunjukkan rule aktif yang memblokir traffic sesuai cakupan CR 1010. Tinjauan dokumentasi CR 1010 pada sistem manajemen perubahan: status approval belum lengkap. Mismatch terverifikasi. R: ISO/IEC 27001:2022 Annex A.8.32 dan A.8.20; Kebijakan Internal PNP/IT/004/2023 butir 1 (Proses Formal) dan butir 2 (Persetujuan Wajib). Risiko: Ketersediaan layanan, firewall rule tanpa validasi Business Operations Lead berpotensi memblokir traffic sah. Risiko integritas konfigurasi jaringan. Risiko audit trail dan akuntabilitas. Risiko bypass control sistemik – kemungkinan ada CR lain di luar sampel dengan pola serupa.	Major	Tidak adanya technical enforcement (workflow gating) pada change management system yang mencegah implementasi production jika approval belum lengkap. Proses approval saat ini bergantung pada kepatuhan manual sehingga rentan terhadap bypass akibat tekanan operasional atau urgensi.	1. Retroactive approval CR 1010 dengan tinjauan teknis dan bisnis oleh Infrastructure Lead dan Business Operations Lead. Jika approval tidak diberikan, lakukan rollback firewall rule terkait. 2. Extended sampling minimal 20 CR tambahan dalam 12 bulan terakhir untuk verifikasi tidak ada penyimpangan serupa. 3. Implementasi technical workflow gating pada change management system. 4. Integrasi dengan IaC pipeline dan CI/CD dengan policy-as-code untuk firewall changes. 5. Tetapkan kebijakan: 'No production network change without complete change approval AND peer review.'	14 hari (retroactive approval); 45 hari (extended sampling); 90 hari (workflow gating sistemik) sejak closing meeting	Open

III. CATATAN AUDITEE – Response & Evidence

Auditee: Head of Engineering; Tim Engineering PT Jelajah Dunia

Due Date	Finish Date	Response, Commitment, & Evidence	Evidence	Remark

Pengesahan Working Paper

Working paper ini disusun secara objektif berdasarkan bukti yang dikumpulkan selama periode audit 6-24 Januari 2026 dan merupakan dokumen pendukung Laporan Audit Internal LAI/ISMS/001/I/2026.

Disusun oleh,
Tim Audit Internal

Mengetahui,
Top Management PT Jelajah Dunia

Syahril Arfian Almazril
Ketua Tim Audit Internal
Tanggal: 24 Januari 2026

[Nama Top Management]
Management Representative
Tanggal: _____